

NOTICE

Este directorio contiene reglas de análisis estático Semgrep de varias procedencias, con licencias distintas. Lee esta nota antes de añadir, copiar o redistribuir cualquier contenido de aquí. Índice completo (id, ruta, fuente, licencia, fecha de revisión) en [registry.json](#).

Total: 778 reglas

Carpeta	Fuente	Licencia	Reglas	Restricciones relevantes
third-party/trailofbits/	trailofbits/semgrep-rules	AGPL-3.0	112	Copyleft: cualquier modificación debe mantenerse AGPLv3 con el aviso de licencia intacto
third-party/opengrep/	opengrep/opengrep-rules	LGPL-2.1 + Commons Clause	556	Prohíbe vender el software (proveer a terceros por una tarifa cuyo valor derive sustancialmente de él); uso interno/redistribución a colaboradores permitido
third-party/elttam/	elttam/semgrep-rules	MIT	6	Ninguna restricción relevante más allá de mantener el aviso de copyright
third-party/0xdea/	0xdea/semgrep-rules	MIT	40	Ninguna restricción relevante más allá de mantener el aviso de copyright
custom/	Propias	A definir	64	Obra propia, sin restricción de redistribución

Metodología aplicada a cada fuente

- **trailofbits** (112): revisión manual completa fila-por-fila (patrón, breadth, severity/confidence, referencias) — ver [.claude/rules-audit-report.md](#), Fase 1. 8 reglas del set original se rechazaron.
- **custom** (64): escritas desde cero en 5 tandas, cada una con test propio verificado, sin partir del código de ninguna regla de terceros — ver [.claude/vulnerability-mapping.md](#) para el subconjunto de frameworks (Django/Flask/Express/Spring/Rails) con CVEs reales de referencia.
- **opengrep, elttam, 0xdea** (602 en total): criterio automático — pasa `semgrep --test + metadata.category == security + metadata.confidence` distinto de `LOW`. Sin revisión manual de patrón individual (inviabile al volumen de las fuentes originales, miles de reglas). Un fichero YAML roto en cualquiera de estas fuentes tumba el test de toda la carpeta que lo contiene, así que se

testeó carpeta por carpeta (y en las carpetas grandes, un nivel más de profundidad) para no perder contenido bueno por un solo fichero malo; el detalle de qué subcarpetas se recuperaron y cuáles no está en [.claude/rules-audit-report.md](#).

Qué NO está aquí, y por qué

Se evaluaron ~2.988 reglas adicionales del registro oficial de Semgrep ([semgrep/semgrep-rules](#)) y otras dos fuentes agregadas ([j3ssie/curated-semgrep-rules](#), [tuannq2299/semgrep-rules](#), más la herramienta [iosifache/semgrep-rules-manager](#)). Ninguna de esas se incluyó:

- [semgrep/semgrep-rules](#) (**registro oficial**): aunque ~1.175 de sus reglas pasaban los criterios de calidad, están bajo la **Semgrep Rules License v1.0**, que prohíbe expresamente la redistribución ("no puedes distribuir las reglas, ni ponerlas a disposición de otros"), incluso en un repositorio privado con colaboradores. [opengrep/opengrep-rules](#) (incluido arriba) es un fork del mismo contenido bajo una licencia mucho menos restrictiva y cubre gran parte del mismo terreno.
- [j3ssie/curated-semgrep-rules](#) y [tuannq2299/semgrep-rules](#): mayoritariamente rotas (fallan su propio `semgrep --test`) al probarlas contra la versión actual de Semgrep, salvo por contenido que ya era una copia desactualizada de trailofbits (ya cubierta directamente).
- [iosifache/semgrep-rules-manager](#): no es un repo de reglas, es una herramienta que agrega 14 fuentes de terceros; 11 de esas 14 ya estaban cubiertas por las fuentes de arriba, y las 3 restantes ([akabe1](#), [atlassian-labs](#), [apiiro](#)) no tenían tests o fallaban todos los suyos.

Detalle completo de la metodología, cifras y decisiones de cada tanda en [.claude/rules-audit-report.md](#) y [.claude/README.md](#).